

Hardening Hyper V

Host OS

- Enable TPM 2.0 + BitLocker
- Minimize installed roles/features
- Disable unnecessary hardware/device redirection
- Keep host and firmware patched

Network

- Keep physical network adapters on separated dedicated VLAN with firewalls configured
- Disable unused Hyper-V virtual switch extensions
- Encrypt live migration traffic

Access Controls

- RBAC
- Restrict SSH/RDPf

Storage and File Security

- Encrypt physical drives on the host storing OS binaries and VM configuration files (ie. Bitlocker)

Monitoring & Recovery

- Enable auditing/logging
- Back up host configuration and VM checkpoints

VM

- Set resource limits
- Disable unneeded Integration Services
 - e.g., guest file copy
 - clipboard sharing, drag-and-drop, or shared folders
- Utilize snapshots to update patches or make any configuration changes to production environments

Changes:

Enable VBS, HVCI, and LSA Credential Guard

```
PS C:\Users\labadmin> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\DeviceGuard" -Name "EnableVirtualizationBasedSecurity" -Value 1 -Type DWord
PS C:\Users\labadmin> Set-ItemProperty -Path "HKLM:\SYSTEM\CurrentControlSet\Control\Lsa" -Name "LsaCfgFlags" -Value 1 -Type DWord
PS C:\Users\labadmin>
```

Block RDP Redirection

```
PS C:\Users\labadmin> Set-VMHost -EnableEnhancedSessionMode $false
```

Enable CredSSP (Compare to Kerberos)

```
PS C:\Users\labadmin> Set-VMHost -VirtualMachineMigrationAuthenticationType CredSSP
```

Lab Directions:

Scenario: Who Gets the Keys?

RBAC Design — Meridian Trust Bank (45 min, teams)

The Situation

Meridian Trust Bank runs its online banking platform on one Hyper-V host. An audit just found that **everyone with any virtualization responsibility is a local administrator on that host.** Nobody can say who is allowed to delete a VM.

Your team designs the fix.

The Host

****HV-INSTRUCTOR01****

| VM | What it does |

|---|---|

| `web-tier` | Public-facing online banking site |

| `app-tier` | Transaction processing — holds the wire transfer queue |

| `db-tier` | Customer data and card numbers |

The People

| Person | What their job actually requires |

|---|---|

| ****Marcus**** — Virtualization Engineer | Patches the host, configures virtual switches and storage. Also holds Domain Admin. |

| ****Priya**** — App Support | Reboots `web-tier` and `app-tier` during Thursday releases. Nothing else. |

| ****Tom**** — DBA | Works inside `db-tier`. Wants to take checkpoints before schema changes. |

| ****Dana**** — Backup vendor | Nightly backups. Her vendor asked for "administrator rights." |

| ****Kevin**** — NOC Tier 1 | Watches a dashboard overnight. Sees if VMs are up. Escalates everything else. |

Your Deliverables

1. ****Role matrix**** — one row per role. Columns: role name, what it can do, what it explicitly cannot do, which VMs it applies to, who gets it.
2. ****Groups, not people**** — name the security groups you'd create. Nobody gets permissions on their individual account.
3. ****How you'd enforce it**** — name the actual mechanism on this host. If Hyper-V can't enforce something in your matrix, say so and describe what you'd do instead.
4. ****One risk you can't fix**** — one or two sentences to the CISO.

Rules

- Every permission must trace to a job duty listed above. If you can't point to the duty, delete the permission.
- "We trust them" is not a control.

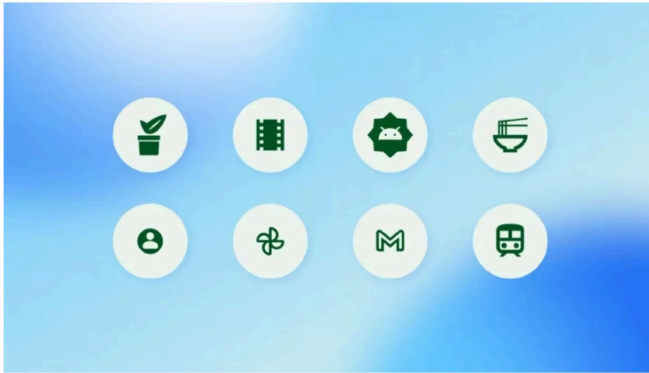
Debrief Questions

1. Should Tom get checkpoint rights on `db-tier`? What is a checkpoint of that VM, exactly?
2. Marcus holds Domain Admin *and* hypervisor admin. What happens if he gets phished?
3. Dana's vendor asked for admin. What does backup software actually need?
4. Priya only reboots things. `app-tier` holds the wire transfer queue. Is that low-privilege?

Role / Security Group	Member	Allowed Actions	Explicitly Denied Actions	Target Scope	User Password
HV-Admin	Marcus	Full host configuration (patches, virtual switches, storage).	Log into guest OS of any VM. AD access; should come from a separate role.	Full Host (HV-INSTRUCTOR01)	Markatwork1234!
AD-Admin	Marcus	Manage AD users, groups, GPOs, domain trust	Cannot log into guest OS of any VM	Domain-wide (not host-scoped)	Markatwork1234!

HV-AppSupport	Priya	Restart-VM.	Modifying VM settings, accessing console, checkpoints, deleting VMs.	web-tier, app-tier	Pr1234!
HV-DBA	Tom	Checkpoint-VM	Starting, stopping, or modifying hardware settings.	db-tier	Tm1234!
HV-BackupOps	Dana	Access Volume Shadow Copy (VSS) APIs for nightly backups.	Modifying VMs, console access, altering host configurations.	Full Host	Dn1234!
HV-NOC-Read	Kevin	Get-VM (View state/uptime for dashboard).	Any state change (start, stop, reboot), configuration changes.	All VMs	Kn1234!

Key Takeaways: Week 3



This week built from a single virtual machine to a defended enterprise virtualized environment, covering both the foundational technology and the two core security strategies that make it defensible. These takeaways represent the core of what this week's program has established.

Virtualization Fundamentals

Virtual machines abstract hardware into software-defined compute resources. Type 1 hypervisors provide the performance and isolation required for enterprise deployments. This foundation makes everything else in the week possible.

Enterprise-Scale Management

Managing VMs at scale requires centralized platforms that enforce consistent policy, maintain audit logs, and provide the visibility necessary for both operations and security across large, multi-host environments.

Secure Access Control

RBAC, MFA, and management network segmentation limit the attack surface and reduce how many ways an attacker can reach sensitive systems or administrative interfaces in the virtualized environment.

Monitoring and Incident Response

Continuous monitoring across VM, host, and network layers catches what access control does not stop. Incident response converts detection into containment and recovery. Together, these complete a defensible enterprise security program.

Virtualization Fundamentals

- Talked about the difference between type 1 & 2 hypervisors and server-side vs client-side
- Isolation (Memory, Network, Storage, CPU)

Enterprise-Scale Management

- Utilize type 1 hypervisors for security reasons
- Type 1 hypervisors (ESXi, Hyper-v, KVM, XEN) manage VMs and how their resources are distributed
- ESXi's vSphere manages hypervisor hosts and performs centralized management
 - vMotion
 - Through shared storage, can move VMs between different EXSi hosts
 - HA
 - Restarts failed hosts on surviving hosts in the cluster
 - Distributed Resource Scheduler (DRS)
 - Monitors vCPU and memory across the cluster and migrates VMs to balance load

Secure Access Control

- RBAC via vSphere
 - Create users and add them to groups with privileges using the principle of least privilege
- Implement MFA
- Use PAM techniques for securing credentials and access
 - Credential vaulting
 - Session Recording
 - Just-In-Time Access

- Certificate based authentication for Management Tools
 - TLS to authenticate connections
- Can utilize and jump server or PAW for extra security

Monitoring and Incident Response

- VM-level monitoring
 - Monitors processes, file changes, user actions, and network connections inside the guest OS
- Host-level monitoring
 - Operates at the hypervisor layer and monitors events such as VM creation, live migration, snapshot activity, and changes to virtual hardware configurations.
 - Create a weekly or monthly baseline to flag unusual activity

IR

1. Isolate the machine from the network
2. Create a snapshot of the machine

After a VM is compromised, we can

- Roll back
 - When a clean snapshot exists and we can patch the vulnerability
- Rebuild from scratch
 - Unsure of what was affected and no trusted snapshot exists